

Interview Guide (Requirements)

1. Project Context and Typical Use Cases

1.1 In what types of projects do you currently use AI, and at which points in the process from idea to operation do you need, from your perspective, an early decision on whether AI Act or DORA obligations are triggered?

1.2 When you think about these use cases: Which characteristics determine, from your perspective, whether a use case becomes “sensitive”?

1.3 Which technology or sourcing model represents the most important use case in practice or in the project context, and which of these models make the regulatory assessment particularly complex?

1.4 What consequences would these models have for the placement of checkpoints in the decision tree, i.e., which checkpoints are needed?

2. EU AI Act

2.1 Scope

2.1.1 Which two to three core criteria do you use in practice to decide whether a project falls within the scope of the AI Act and should therefore be asked about first in a decision tree?

2.1.2 Which system characteristics are indispensable for this initial decision so that later detailed assessments are meaningful?

2.1.3 Where do most borderline cases or unclear situations arise in practice, and how would you like these to be addressed in a single branch of the decision tree?

2.1.4 Which assessment questions help to reach a conclusive evaluation in these cases?

2.1.5 If general-purpose AI models are involved, which additional check should, from your perspective, necessarily be carried out before the process is continued from a subject-matter perspective?

2.1.6 Which documents or evidence would you expect in a standardized form so that the decision tree can later link directly to them?

2.2 Role Check

2.2.1 Which role constellations occur most frequently in your organization and should therefore appear as predefined options in the decision tree?

2.2.2 What impact does a change of role have on the scope of obligations, and should this therefore appear as a separate path in the decision tree?

2.3 Classification as High-Risk AI

2.3.1 Which three to four practical indicators do you use to quickly identify “high-risk AI by intended purpose” before moving into the detailed requirements?

2.3.2 Which evidence do you typically rely on for this assessment, so that the decision tree should output it as “expected evidence”?

2.3.3 If a high-risk AI system is present, which groups of obligations should, from your perspective, always be triggered as a package?

2.3.4 Which additional documents repeatedly occur in practice and should therefore be stored as optional but recommended evidence?

3. DORA

3.1 Integration into the ICT Landscape

3.1.1 How is the planned integration of an AI system into a financial organization implemented in the sense of DORA?

3.1.2 Is the AI system planned as an independent ICT component with its own operational responsibility, or is it integrated into an existing important or critical ICT application?

3.1.3 Which technical dependencies on internal systems or external ICT service providers, including subcontractors, should always be queried in the decision tree because they are typically relevant under DORA?

3.1.4 Which information required for the asset register and the information register under DORA is, in relation to an AI application, the most difficult for you to obtain and keep up to date?

3.2 Critical or Important Functions

3.2.1 Which criteria do you use to decide whether an AI system affects a critical or important function within the meaning of DORA and should therefore be assigned to a stricter path?

3.2.2 DORA distinguishes major ICT incidents, among other things, according to the duration of the disruption, the number of affected users, and the type or extent of data loss. Which scenarios should therefore at least be queried in the decision tree so that these severity levels can be derived?

3.2.3 For which types of external ICT services could DORA requirements be defined in a reduced form from a risk perspective, and for which types would this not be appropriate?

3.3 DORA Process Obligations

3.3.1 Specifically for AI: Which additional control points are needed compared with traditional ICT systems to detect changes in data or model behavior over time?

3.3.2 Which of these types of evidence are particularly critical from an audit perspective and should therefore be explicitly output as a result of the decision tree?

4. Presentation of Results and Evidence

4.1 In what form should the results of such a decision tree be provided so that they are actually used in projects?

4.2 What would be a suitable output structure from your perspective?

4.3 Which formal approvals or role confirmations must be visible in the result so that the decision tree can be applied not only from a subject-matter perspective but also organizationally in practice?

4.4 Which formats and links do you typically need?

5. Role-Specific Deepening - Interviews 1 and 2

5.1 Which minimal decision questions do you use to arrive at “critical/important” in one or two steps, and which of these should necessarily be adopted by the decision tree?

5.2 Which types of evidence typically achieve the highest acceptance among auditors or reviewers?

5. Role-Specific Deepening - Interview 3

5.1 Which controls must always be included in the decision tree, regardless of how “lean” the project is?

5.2 How do you currently classify ICT or security incidents and which criteria do you use for this?

5. Role-Specific Deepening - Interview 4

5.1 At which steps of secure AI integration do you conduct data protection assessments?

5.2 Which substantive aspects do you typically assess?

5.3 How are the results of your assessments reused?

6. Closing Questions

6.1 Acceptance and success criteria: Which performance indicators are particularly helpful from your perspective for measuring success?

6.2 Borderline cases: Which sensitive or difficult cases must be covered?

6.3 How would you solve these cases in terms of path logic?

6.4 Maintenance and versioning: In which areas are requirements subject to a high degree of change?

6.5 How would you like the versioning of these changes to be reflected in the result?